

SIMATS ENGINEERING

ASSESSMENT TOOL 1

Name	SHAIK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO4: Appraise containment, eradication, recovery strategies by selecting appropriate techniques such as isolation, malware removal, patch management, system restoration to ensure secure operations. (BL3, BL4)

Activity Tool : Incident Containment and Isolation Lab (High)

Assessment Tool Weightage: 40%

Code of Conduct:

I _____shaikreehan192565071_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Shaik Reehan

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Incident Identification and Scope Analysis	20%	Accurately identifies the incident, affected systems, attack indicators, and scope of compromise using relevant evidence.	Identifies the incident, affected systems, and major indicators with minor omissions.	Identifies basic incident details but misses important indicators or affected systems.	Unable to correctly identify the incident or determine its scope.
Containment and Isolation Techniques	25%	Effectively implements short-term and long-term containment and correctly isolates affected systems while minimizing business disruption.	Implements appropriate containment and isolation with minor errors or omissions.	Performs basic containment but misses important isolation steps or controls.	Unable to implement appropriate containment or isolation techniques.
Blocking Malicious Access	20%	Accurately identifies and blocks malicious IPs, ports, accounts, processes, or network connections using appropriate security controls.	Blocks most malicious access using suitable controls with minor gaps.	Performs limited blocking but leaves some malicious access paths unresolved.	Unable to effectively block malicious access.
Eradication and Vulnerability Remediation	20%	Completely removes malware and malicious components, identifies the exploited vulnerability, applies appropriate remediation, and verifies successful eradication.	Removes malware and applies appropriate vulnerability remediation with minor verification gaps.	Performs basic malware removal or remediation but leaves some risks unresolved.	Unable to remove malware or remediate the underlying vulnerability.
Documentation and Incident Report	15%	Provides clear, professional documentation covering investigation, containment actions, evidence, remediation, timeline, findings, and final outcome.	Documentation is well organized with most required evidence and actions.	Documentation is partially organized and lacks important evidence or details.	Documentation is incomplete, poorly organized, and lacks supporting evidence.

1. Network Segmentation for Incident Containment

Introduction

Network segmentation is an important incident-containment technique used to prevent an infected system from communicating with other critical systems. In this scenario, malware is spreading from the **user network toward critical database servers**. The primary objective is to stop lateral movement, isolate compromised systems, protect critical assets, and allow security teams to investigate and eradicate the malware without causing unnecessary business disruption.

1. Incident Identification and Scope Analysis

First, the security team should identify the infected systems and determine how far the malware has spread.

Important evidence includes:

- SIEM and firewall logs
- Endpoint Detection and Response (EDR) alerts
- Unusual network connections
- Suspicious processes and files
- Repeated authentication failures
- Unexpected traffic between user systems and database servers
- Malware indicators such as malicious IP addresses, domains, hashes, and ports

The affected systems should be classified into groups such as:

- **User VLAN** – employee computers and laptops
- **Server VLAN** – application and internal servers
- **Database VLAN** – critical database servers
- **Management VLAN** – administrative systems
- **Security/Monitoring VLAN** – SIEM, IDS/IPS and security tools

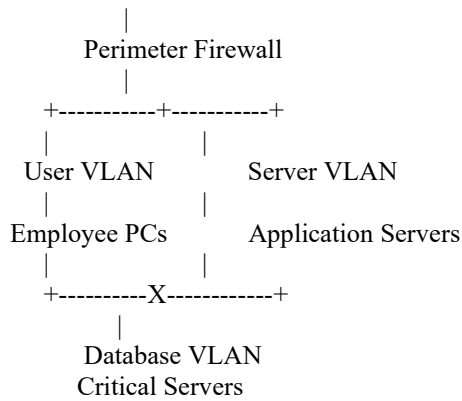
This helps determine the scope of compromise and identifies which systems require immediate isolation.

2. VLAN-Based Segmentation

VLANs can divide the organization's network into logically separated security zones.

For example:

Internet



The infected user network should not have unrestricted access to the database VLAN. Communication should occur only through authorized services and approved network paths.

For example:

- User VLAN → Application Server: **Allowed**
- User VLAN → Database Server: **Blocked**
- Application Server → Database Server: **Allowed only on required database port**
- User VLAN → Management VLAN: **Blocked**
- Guest VLAN → Internal Network: **Blocked**

This reduces the attack surface and prevents malware from directly reaching critical databases.

3. Firewall Controls

Firewalls should enforce communication between different network segments.

During the incident, temporary firewall rules can be introduced to block:

- Malicious IP addresses
- Suspicious domains
- Unnecessary ports
- Unauthorized protocols
- Connections from infected hosts
- Direct user-to-database communication

For example:

```

ALLOW User_VLAN → Application_Server : Required_Service
ALLOW Application_Server → Database_VLAN : Database_Port
DENY User_VLAN → Database_VLAN : Any
DENY Infected_Host → Internal_Network : Any
DENY Malicious_IP → Internal_Network : Any
  
```

The rules should follow the **least-privilege principle**, allowing only the communication that is necessary for business operations.

4. Access-Control Rules

Access-control lists (ACLs) should be applied to switches, routers, and firewalls.

ACLs can restrict:

- Source IP addresses
- Destination IP addresses
- Ports
- Protocols
- VLAN-to-VLAN communication

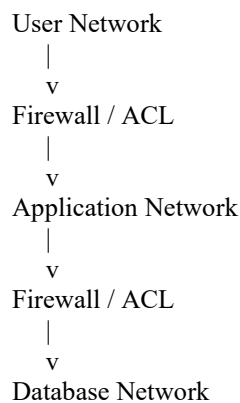
For example, a user workstation should not be permitted to directly establish a database administration connection. Only authorized application servers or administrators should have that access.

Network Access Control (NAC) can also be used to automatically place suspicious or non-compliant devices into a quarantine VLAN.

5. Restricted Communication Paths

Communication between network segments should follow controlled paths rather than allowing unrestricted connectivity.

A secure architecture would be:



This makes it more difficult for malware to move directly from a compromised workstation to critical databases.

6. Short-Term and Long-Term Containment

Short-term containment:

1. Identify infected hosts.
2. Disconnect severely compromised systems from the network.
3. Move suspicious devices to a quarantine VLAN.
4. Block malicious IPs, domains, ports, and connections.
5. Restrict communication between user and database networks.
6. Disable compromised accounts where necessary.

Long-term containment:

1. Redesign VLAN boundaries.
2. Implement internal firewalls.
3. Apply least-privilege ACLs.
4. Deploy NAC and EDR.
5. Introduce Zero Trust principles.
6. Continuously monitor east-west traffic between internal systems.

7. Eradication and Verification

After containment, the security team should remove the malware and identify the vulnerability that allowed the infection.

Actions include:

- Remove malicious files and processes.
- Reimage severely compromised machines.
- Reset compromised credentials.
- Patch exploited vulnerabilities.
- Remove persistence mechanisms.
- Scan affected systems.
- Verify that malicious network connections no longer exist.

The environment should be monitored after remediation to ensure that the malware does not return.

8. Documentation

Every incident-response action should be documented, including:

- Time of detection
- Affected systems
- Indicators of compromise
- Network segments involved
- Firewall and ACL changes
- Hosts isolated
- Malware discovered
- Vulnerability exploited
- Eradication actions
- Verification results
- Final incident outcome

Conclusion: Network segmentation provides an effective defense against lateral movement. By separating users, applications, databases, and management systems using **VLANs, firewalls, ACLs, NAC, and restricted communication paths**, the organization can contain malware and protect critical database servers. Combining segmentation with monitoring, eradication, vulnerability remediation, and proper documentation provides a complete incident-response approach.

2. Patch Management During Incident Response

Introduction

After a malware incident reveals that several systems are vulnerable because security patches were not applied, the organization must establish a structured patch-management strategy. The objective is not simply to install every available patch immediately, but to **identify vulnerabilities, prioritize them according to risk, safely test patches, deploy them systematically, verify successful installation, and continuously monitor the environment.**

1. Incident Identification and Vulnerability Assessment

The first step is to determine which vulnerabilities contributed to the incident.

The security team should collect information from:

- Vulnerability scanners
- Asset inventories
- EDR systems
- SIEM logs
- Vendor security advisories
- Patch-management systems
- Incident investigation results

Each vulnerability should be associated with the affected asset.

For example:

Asset	Vulnerability	Risk	Action
Database Server	Critical RCE	Very High	Immediate patch
Application Server	High vulnerability	High	Priority patch
Employee PC	Medium vulnerability	Medium	Scheduled patch
Test System	Low vulnerability	Low	Normal patch cycle

2. Vulnerability Prioritization

Patches should be prioritized based on risk rather than simply their release date.

Priority should consider:

- **CVSS severity**
- Whether the vulnerability is actively exploited
- Whether it was used during the incident
- Internet exposure

- Criticality of the affected asset
- Availability of public exploits
- Business impact

A practical priority order is:

Actively exploited + Critical asset
↓
Critical vulnerability + Internet exposed
↓
High-risk vulnerability
↓
Medium-risk vulnerability
↓
Low-risk vulnerability

The vulnerability exploited by the malware should receive the highest priority.

3. Patch Testing

Before deploying patches across the entire organization, patches should be tested in a controlled environment.

The organization should:

1. Create a test environment.
2. Install the patch on representative systems.
3. Test applications and services.
4. Check system performance.
5. Verify network connectivity.
6. Confirm that security controls continue functioning.
7. Document compatibility problems.

For critical systems such as databases, testing is particularly important because an unsuccessful patch could interrupt important business services.

4. Patch Deployment

After successful testing, patches should be deployed in stages.

A possible deployment strategy is:

Test Environment
↓
Pilot Systems
↓
Low-Risk Production Systems
↓
Important Production Systems
↓
Critical Servers

For emergency vulnerabilities actively exploited by attackers, the organization may perform an **accelerated emergency patch deployment** after appropriate testing or risk assessment.

Before deployment:

- Back up important data.
- Create recovery procedures.
- Schedule maintenance windows.
- Notify affected users.
- Confirm system availability.

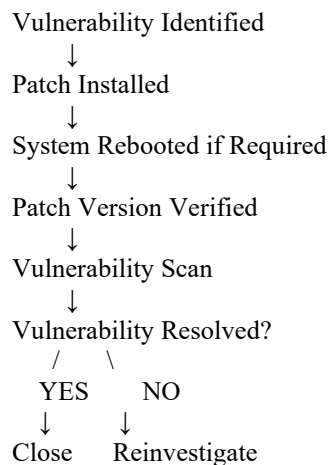
5. Verification

Installing a patch is not enough. The organization must verify that remediation was successful.

Verification should include:

- Confirming the correct patch version.
- Running vulnerability scans again.
- Checking EDR status.
- Reviewing system logs.
- Testing affected applications.
- Confirming that vulnerable services are no longer exposed.
- Checking whether the original exploit still works in authorized security testing.

For example:



6. Continuous Patch Monitoring

Patch management should become a continuous security process rather than a one-time response.

The organization should maintain:

- Centralized asset inventory

- Automated patch-management tools
- Regular vulnerability scans
- Patch compliance reports
- Security-alert monitoring
- Vendor advisory monitoring
- Patch deadlines based on severity
- Exception tracking

For example, management can define targets such as:

- Critical vulnerabilities: immediate/emergency remediation
- High vulnerabilities: rapid remediation
- Medium vulnerabilities: scheduled remediation
- Low vulnerabilities: regular maintenance cycle

Unpatched systems should generate alerts for security administrators.

7. Handling Systems That Cannot Be Patched

Some legacy systems may not support the required patch.

In such cases, compensating controls should be applied, such as:

- Network isolation
- Firewall restrictions
- Disabling unnecessary services
- Application allowlisting
- Additional EDR monitoring
- Restricting administrative access
- Virtual patching through intrusion-prevention controls

These systems should be tracked as documented exceptions until they can be upgraded or replaced.

8. Documentation and Incident Report

The organization should document:

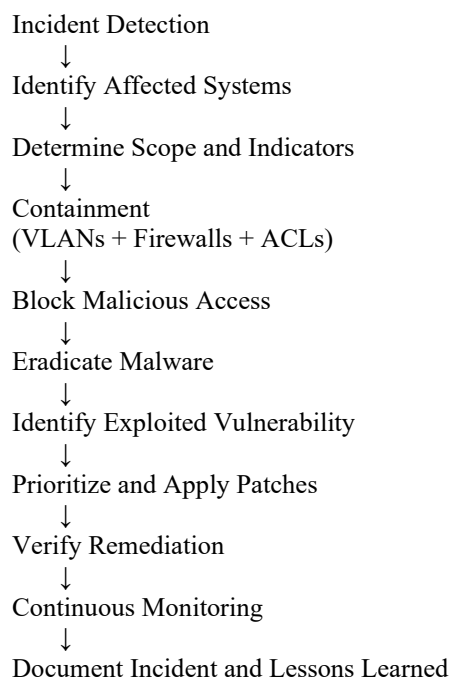
- Vulnerabilities discovered
- Systems affected
- Vulnerability severity
- Patch versions
- Testing results
- Deployment dates
- Failed installations
- Verification results
- Exceptions
- Compensating controls
- Final remediation status

The incident report should also identify **why the patches were missed** and recommend improvements to prevent recurrence.

Conclusion

An effective patch-management strategy follows a continuous cycle of **identify** → **prioritize** → **test** → **deploy** → **verify** → **monitor**. By prioritizing actively exploited and critical vulnerabilities, carefully testing patches, deploying them systematically, verifying remediation, and continuously monitoring patch compliance, the organization can significantly reduce the likelihood of another malware incident.

Overall Incident-Response Flow



•